

RELATÓRIO DE PENETRATION TESTING (RED TEAM)

Controlo do Documento

Cliente / Organização: IEFP Faro - Laboratório CET Cibersegurança
Autor do relatório: Andrey Dudkin - Técnico Especialista em Cibersegurança (formando)
Data do teste: 17 de julho de 2026

1. Identificação e Enquadramento

Target (host / rede / aplicação): srv-ubuntu-blueteam (VM Ubuntu Server, laboratório Blue vs Red Team)
Endereço(s) IP: 100.84.78.52 (srvbt.tail74269e.ts.net)
Tipo de teste: White-box / acesso prévio a informação detalhada sobre o alvo
Metodologia utilizada: PTES + Cyber Kill Chain (Lockheed Martin)
Âmbito autorizado (Rules of Engagement): Testar exclusivamente o servidor Ubuntu do exercício (100.84.78.52). Dentro do âmbito: serviços FTP (21), SSH (22), HTTP/HTTPS (80/443). Fora do âmbito: qualquer outro host da rede, ataques destrutivos (DDoS, apagar dados), alteração de configurações críticas sem autorização.

1.1 Ativos Testados

Ativo / Host	IP	SO / Serviço	Criticidade
srv-ubuntu-blueteam	100.84.78.52	Ubuntu Server / vsftpd 3.0.5, OpenSSH 9.6p1, Apache 2.4.58	Alta (ambiente de laboratório)
VM-KALI (atacante)	100.114.252.67	Kali Linux	N/A

2. Resumo Executivo

Durante o exercício foi confirmado que o servidor alvo expunha dois vetores de acesso não autenticado: um serviço FTP com login anónimo e permissão de escrita, e um serviço SSH protegido apenas por uma password fraca. Ambos foram explorados com sucesso, permitindo depositar um ficheiro de prova no servidor e obter acesso interativo via SSH. A partir desse acesso foram localizados e exfiltrados dois ficheiros sensíveis contendo credenciais. O impacto é elevado: um atacante externo teria obtido acesso à conta admin e a dados de autenticação armazenados no sistema, sem necessitar de qualquer exploit sofisticado.

2.1 Resumo Técnico (para a equipa Red Team / Blue Team)

O reconhecimento com nmap identificou as portas 21, 22, 80 e 443 abertas, com vsftpd 3.0.5, OpenSSH 9.6p1 e Apache 2.4.58. O acesso FTP anónimo foi confirmado de imediato (230 Login successful), com escrita ativa na pasta /upload, onde foi depositado o ficheiro powned_by_redteam.txt. A enumeração web com dirsearch não revelou diretórios sensíveis (apenas respostas 403 e /server-status). O vetor de sucesso principal foi o brute force SSH com Hydra contra o utilizador admin, que obteve a credencial válida (admin / "-password-")

após cerca de 245 tentativas em 3m40s. A partir do acesso SSH foram exfiltrados via SCP dois ficheiros: /tmp/passwords.txt (ficheiro isca com hashes SHA-256, contendo um aviso embutido de que o acesso estava a ser registado) e /tmp/zzz.txt (credenciais adicionais não previstas no âmbito inicial).

2.2 Classificação Geral de Risco

Nível de risco global: Crítico

CVSS v3.1 (score base): 9.1 - cadeia FTP anónimo + SSH brute force

3. Timeline do Ataque

Hora (UTC)	Fase (Kill Chain)	Ação / Comando
10:05	Reconnaissance	nmap -sV 100.84.78.52 — 21/22/80/443 abertos
10:08	Delivery / Initial Access	ftp 100.84.78.52 (anonymous) → login 230 Login successful
10:10	Actions on Objectives (parcial)	cd upload; put pwned_by_redteam.txt → 226 Transfer complete
10:12	Reconnaissance (web)	dirsearch -u http://100.84.78.52/ → maioria 403, /server-status
11:19:08 – 11:22:48	Exploitation (brute force)	hydra -l admin -P wordlist.txt ssh://100.84.78.52 -V → credencial válida em ~245 tentativas
10:25	Installation / C2 (shell)	ssh admin@100.84.78.52 → acesso interativo confirmado
10:29:29	Actions on Objectives	scp admin@100.84.78.52:/tmp/passwords.txt ./passwords_exf.txt
10:32	Actions on Objectives	scp admin@100.84.78.52:/tmp/zzz.txt ./zzz_exf.txt

4. Vulnerabilidades Identificadas

4.1 FTP Anonymous Login com Escrita

Nome: vsftpd — Anonymous Login + Write Permission

CVE / Referência: N/A (erro de configuração; mitigação relacionada com CVE-2011-0762 já aplicada na raiz do chroot)

Severidade: Alta

CVSS v3.1: 7.5

Componente afetado: vsftpd 3.0.5, porta 21/TCP, diretório /srv/ftp/upload

Descrição:

O serviço FTP aceita autenticação anônima (anonymous_enable=YES) e permite escrita na subpasta upload (anon_upload_enable=YES, permissões 777). Isto permite a qualquer atacante não autenticado listar conteúdo e depositar ficheiros arbitrários no servidor, sem necessidade de credenciais válidas.

4.2 SSH - Password Fraca / Brute Force

Nome: OpenSSH - Weak Password Authentication

CVE / Referência: N/A (fraqueza de configuração/credencial)

Severidade: Crítica

CVSS v3.1: 9.8

Componente afetado: OpenSSH 9.6p1, porta 22/TCP, utilizador admin

Descrição:

O serviço SSH tem autenticação por password ativa (PasswordAuthentication yes) e a conta admin utiliza uma password fraca, facilmente quebrável por dicionário. Sem rate-limiting eficaz ao nível do serviço, o ataque de força bruta com Hydra obteve a credencial válida em menos de 4 minutos (~245 tentativas).

5. Prova de Exploração

5.1 Acesso FTP Anónimo

```
$ ftp 100.84.78.52
Name: anonymous
Password: <Enter>
230 Login successful.
ftp> ls -la
ftp> cd upload
ftp> put pawned_by_redteam.txt
226 Transfer complete.
```

Explicação:

O login anónimo foi aceite de imediato, sem qualquer credencial. A pasta upload confirmou permissões de escrita (drwxrwxrwx), permitindo o depósito do ficheiro de prova pawned_by_redteam.txt, confirmando a exploração completa deste vetor.

5.2 Brute Force SSH com Hydra

```
$ hydra -l admin -P ~/Desktop/passwords_pt.txt ssh://100.84.78.52 -V
[DATA] attacking ssh://100.84.78.52:22/
...
[22][ssh] host: 100.84.78.52 login: admin password: -password-
1 of 1 target successfully completed, 1 valid password found
```

Tempo decorrido: ~3m40s (11:19:08 -> 11:22:48), ~245 tentativas

Explicação:

O Hydra testou sistematicamente uma wordlist de passwords contra o utilizador admin via SSH. A ausência de rate-limiting (Fail2ban desativado nesta fase do exercício) permitiu completar o ataque sem bloqueio, resultando na descoberta da credencial válida em poucos minutos.

5.3 Acesso SSH e Exfiltração

```
$ ssh admin@100.84.78.52
admin@100.84.78.52's password:
admin@srv-ubuntu-blutteam:~$ cat /tmp/passwords.txt
# (hashes SHA-256 + aviso: "this file access has been logged. IR triggered")

$ scp admin@100.84.78.52:/tmp/passwords.txt ./passwords_exf.txt
$ scp admin@100.84.78.52:/tmp/zzz.txt ./zzz_exf.txt
```

Explicação:

Com a credencial válida foi estabelecido um shell SSH interativo com privilégios do utilizador admin. Foram localizados dois ficheiros com informação sensível: /tmp/passwords.txt (o ficheiro isca da Blue Team, continha um aviso embutido revelando tratar-se de um canário de deteção) e /tmp/zzz.txt (um segundo ficheiro com credenciais adicionais, não previsto no âmbito inicial da preparação). Ambos foram exfiltrados via SCP para a máquina atacante.

6. Impacto

Acesso obtido: Shell interativo SSH (utilizador admin) + acesso de leitura/escrita via FTP anónimo

Privilégios obtidos: admin (utilizador local, sem escalada a root testada - fora do âmbito autorizado)

Dados / sistemas comprometidos: /tmp/passwords.txt (hashes de isca) e /tmp/zzz.txt (hashes de credenciais); ficheiro pwned_by_redteam.txt depositado via FTP

Persistência conseguida?: Não foi criada persistência (fora do âmbito autorizado), mas tecnicamente viável a partir do acesso obtido

Explicação:

Com a credencial admin comprometida e o serviço FTP aberto a escrita anónima, um atacante real teria controlo suficiente para ler, alterar ou depositar ficheiros no sistema, além de exfiltrar dados de autenticação armazenados localmente.

7. Mapeamento MITRE ATT&CK

- T1595 – Active Scanning (reconhecimento com nmap)
- T1190 – Exploit Public-Facing Application (FTP anónimo com escrita)

- T1110.001 – Brute Force: Password Guessing (Hydra contra SSH)
- T1078 – Valid Accounts (uso da credencial admin obtida)
- T1083 – File and Directory Discovery (localização de passwords.txt e zzz.txt)
- T1041 – Exfiltration Over C2 Channel (exfiltração via SCP sobre a sessão SSH)

8. Recomendações

- Desativar de imediato o acesso anónimo e a escrita no vsftpd (anonymous_enable=NO, write_enable=NO) - já aplicado pela Blue Team na Fase 6.
- Eliminar a autenticação por password no SSH, forçando exclusivamente chave pública (PasswordAuthentication no, PubkeyAuthentication yes).
- Reforçar o Fail2ban com maxretry baixo (≤ 3) e bantime progressivo, e mantê-lo sempre ativo fora de exercícios controlados.
- Impor política de passwords fortes (mínimo 16 caracteres, sem palavras de dicionário) para todas as contas com acesso remoto.
- Monitorizar continuamente com um mecanismo tipo canário (como o já implementado pela Blue Team) para deteção precoce de acessos não autorizados a ficheiros sensíveis.

9. Conclusão

O exercício confirmou que a combinação de dois erros de configuração simples - FTP anónimo com escrita e SSH protegido apenas por password fraca - foi suficiente para obter acesso completo ao sistema e exfiltrar dados sensíveis em menos de 30 minutos. Nenhuma das vulnerabilidades exploradas exigiu um exploit sofisticado ou zero-day, o que reforça a importância do hardening básico (desativação de serviços anónimos, autenticação por chave, rate-limiting) como primeira linha de defesa. A deteção por parte da Blue Team foi eficaz e ocorreu durante o próprio ataque, o que valida o valor do mecanismo de canário implementado na Fase 2.